
Understanding Pass-the-Hash Attacks: A Detailed Guide

Key Takeaways

- Pass-the-hash attacks reuse NTLM hashes from LSASS memory to authenticate across Windows systems without plaintext passwords.
- A single domain administrator hash captured on a workstation can unlock full Active Directory control.
- NTLM authentication enables hash reuse; Kerberos reduces exposure but legacy fallbacks keep the attack viable.
- Effective detection depends on network visibility into Logon Type 3/9 activity and abnormal workstation-to-server NTLM flows.
- LAPS, Credential Guard, NTLM restriction, and tiered administration eliminate most real-world attack paths.
- East-west visibility via NDR exposes credential abuse missed by endpoint-only and perimeter-focused tools.

Credential theft powers most sophisticated cyberattacks hitting enterprises in 2026. Attackers grab NTLM hashes from one compromised system and use them to authenticate across entire Windows networks—no plaintext passwords required. This guide breaks down exactly how pass-the-hash attacks work, why detecting them remains challenging, and the layered defenses that stop credential theft.

Why Attackers Steal Credentials to Move Through Networks

Credential attacks succeed because they hijack legitimate identity. Verizon's 2025 DBIR found credential theft involved in nearly half of breaches—far more than vulnerabilities or malware. Attackers grab user credentials that blend perfectly with normal traffic.

Lateral movement becomes the real priority post-breach. Initial access gets attackers onto a workstation. From there, they need to reach domain controllers, database servers, and backup systems without detection.

Pass-the-hash occupies the critical pivot point. MITRE ATT&CK classifies this pass the hash technique as T1550.002 under "Use Alternate Authentication Material." Threat actors chain it with LSASS dumping to convert user access into privileged access. Groups like APT41 and ransomware operators continue heavy usage into 2026.

What Is a Pass-the-Hash Attack?

At its core, pass-the-hash weaponizes Windows credential storage against itself. Attackers extract password hashes from compromised systems and inject stolen hashes directly into authentication protocols targeting remote systems.

NT hashes serve as bearer tokens across Windows systems. Windows stores hashed passwords as MD4 digests in LSASS memory (active sessions) and SAM registry hives (offline accounts). NTLM authentication protocols simply compare submitted hash values against stored reference

values.

Hash validation proves blind to origin. A stolen password hash from a compromised user session extracted from an engineer's laptop passes identically to legitimate usage, inheriting full Group Policy, service control, and resource access across the target environment.

How Authentication Enables Pass-the-Hash

NTLM's challenge-response creates the vulnerability window. Client-server authentication via SMB, RDP, or RPC follows this flow: server sends random nonce → client encrypts using NTLM hash → server validates against stored hash value copy.

Pass-the-hash bypasses the entire process. Attack tools supply the raw 16-byte NTLM hash directly to protocol handlers. Windows accepts this hash technique submission as equivalent identity proof—no challenge generation, no response crafting, no plaintext password required.

Protocol versions expose different weaknesses. NTLMv1 uses weak DES encryption vulnerable to both relay attacks and direct hash reuse. NTLMv2 strengthens challenge protection but fails completely when attackers possess the underlying NTLM hash.

Kerberos helps but doesn't eliminate risk. Ticket-based mutual authentication eliminates direct hash transmission, but NTLM protocol fallback persists for legacy protocols, printer spoolers, and Service Principal Name resolution failures.

How Pass-the-Hash Attacks Work (Step-by-Step)

Step 1: Initial access lands the foothold. [Spear-phishing](#) attachments, exploited vulnerabilities, or compromised VPN credentials deliver domain user access to target workstations.

Step 2: Local privilege escalation unlocks credential stores. UAC bypass techniques or kernel exploits grant local administrator passwords context and SeDebugPrivilege for LSASS memory access.

Step 3: Hash extraction targets active sessions. Tools scrape LSASS.exe to enumerate all logged-on accounts, exporting NTLM hashes for domain users, local administrators, and elevated service principals.

Step 4: Remote authentication propagates compromise. Stolen hashes authenticate via SMB port 445 to file servers, RDP port 3389 to jump hosts, or WMI port 135 to domain controllers.

Step 5: Domain escalation completes takeover. "Overpass-the-hash" converts NTLM hashes to Kerberos TGTs via DC requests, enabling silver/golden ticket forgery.

Why Pass-the-Hash Still Works in Modern Environments

Windows maintains NTLM compatibility. Server 2022 and Windows 11 support legacy protocols for line-of-business applications, medical devices, and industrial controllers rejecting Kerberos negotiation.

Domain admins create high-value targets. Engineers log DA accounts into workstations for troubleshooting. Service accounts receive domain admin rights for application compatibility.

Shared local admin credentials enable rapid spread. Assessments find identical local

administrator passwords across 70-80% of endpoints—one workstation captured hash unlocks the entire server estate.

Network design flaws permit propagation. Flat VLANs without east-west firewalls allow workstation-to-server SMB traffic. Jump servers maintain standing administrator accounts spanning security zones.

Hybrid environments bridge attack surfaces. [Azure AD](#) Connect synchronizes hashes across boundaries while multi-forest trusts expose local accounts to lateral movement.

Still Relying on Manual Response?

- See how automation accelerates your SecOps workflows with smarter efficiency.
- Deep Visibility
- Reduce alert 'noise'
- shorten response times to minutes or seconds

[Get the Whitepaper Now!](#)

Executive Summary

Cyber attacks are no longer isolated incidents as threat actors enjoy continuous evolving, attackers often shift scripts to evade preventive measures, business compromise scenarios outside the scope of defensive entities. Not to be forgotten reconnaissance, quiet entry and persistence within targets.

While the mindset of security leaders keeping bad actors and malware (malicious intruders and insiders) in environments undetected, organizations are prepared and hampered in their effort to breach detection and response efforts.

As attackers continue to spread, leaders have responded by spending dollars to consolidate alerts, even SIEMs with little to no improvement in breach attack detection or response time. Despite investments in technologies, attackers routinely compromise seemingly secure organizations' assets, intellectual property, and

Rather than help, preventive breach detection efforts as they generate multitudes of innocuous fatigue. Alerts multiply as they are detected at different stages, duplication of alerts further adds. More problematic, such technology visibility nor the rich metadata respond to attackers already generated by legacy security contextual information and enable a security analyst to form multiple point products aspects of the attack. Because a common metadata model apply. Without automation speed triage and investigate events while gathering from multiple disparate sources.

4 Keys to Automating Threat Detection, Threat Hunting and Response

Common Tools and Techniques Used in PtH Attacks

LSASS dumping extracts raw credential material. Industry-standard capabilities scrape memory for all active logon sessions, exporting NTLM hashes across logged-on accounts.

[Remote execution](#) frameworks propagate hashes silently. Tool suites authenticate via NTLM hash over SMB, creating temporary services or leveraging WMI for command execution without disk artifacts.

Native Windows utilities blend with legitimate traffic. Built-in binaries execute processes remotely using alternate credential flags, schedule tasks across host ranges, or create time-based triggers.

C2 frameworks chain capabilities automatically. Modern implants sequence hash dumping with host enumeration, [privilege escalation](#), and high-value target prioritization.

Pass-the-Hash vs Related Credential Attacks

Attack Type	Uses Hash	Needs Password	Primary Goal	Detection Difficulty	Pass-the-Hash	Yes	No									
Lateral movement across Windows domains	High—valid NTLM traffic	Pass-the-Ticket	No	No	Kerberos persistence & DC compromise	Medium—ticket anomalies	Credential Dumping	Indirect	No	Harvest stolen password material from LSASS/SAM	Medium—memory access patterns	Brute Force	No	Yes	Enumerate plaintext at login prompts	Low—failed authentication volume

Where Pass-the-Hash Attacks Commonly Succeed

Active Directory tier-zero systems expose maximum impact. Domain controller administrator hashes control Group Policy deployment, DNS manipulation, and certificate authority operations.

Service accounts suffer privilege over-scoping. Group Managed Service Accounts receive domain admin delegation for legacy application compatibility.

Privileged user endpoints cache multiple sessions. Helpdesk laptops maintain concurrent administrator accounts across servers, databases, and network devices.

Legacy Windows lacks modern protections. Server 2012R2 and unpatched Server 2016 ship without Credential Guard or LSA Protection.

Indicators of a Pass-the-Hash Attack

NTLM Logon Type patterns reveal hash reuse. Event ID 4624 Logon Type 3 (network) or Type 9 (new credentials) without preceding Type 2 flags workstation-to-server authentications.

Spatial anomalies expose illegitimate usage. Domain admin credentials originating from engineering workstations rather than management VLANs violate established patterns.

Temporal bursts confirm [lateral movement](#). Single privileged accounts attempting 50+ SMB connections within 15 minutes following LSASS access confirm systematic propagation.

Process relationships tie execution to abuse. Suspicious binaries spawned following privilege use events (4673) confirm remote command execution.

Why Pass-the-Hash Is Hard to Detect

Cryptographic validity defeats [signature detection](#). Legitimate administrator hashes generate identical NTLM traffic patterns whether used during legitimate operations or attacks.

Siloed detection misses cross-domain hops. Endpoint tools capture local dumps but lack network visibility into subsequent remote authentications.

Missing behavioral baselines hide operations. Teams rarely establish service account workstation logins or temporal authentication patterns.

Encrypted SMB3 obscures command execution. [Deep packet inspection](#) fails against payload encryption following successful hash authentication.

How to Detect Pass-the-Hash Activity

[Network monitoring](#) reconstructs authentication flows. NTLM packet analysis reveals hash reuse patterns across encrypted sessions, baselining legitimate administrator behaviors.

Cross-layer correlation confirms attack progression. Endpoint LSASS access events joined with network authentication flows within minutes confirm credential propagation.

SIEM hunting queries expose anomalies. Workstation-to-server NTLM authentications, service accounts from user VLANs, and temporal volume spikes trigger investigation.

[Behavioral analytics](#) establish identity patterns. Machine learning models flag service accounts authenticating interactively or domain admins connecting from unauthorized hosts.

Preventing Pass-the-Hash Attacks

Protocol hardening eliminates attack surface. GPO “Network security: Restrict NTLM: Incoming NTLM traffic” set to Deny All forces Kerberos-only authentication.

Credential isolation breaks shared password dependency. Microsoft LAPS generates unique 128+ character local administrator passwords rotated every 30 days.

Memory protection blocks hash extraction. Credential Guard virtualizes LSASS through Hyper-V isolation, preventing debug access even from local administrator context.

Tiered administration limits privilege scope. Separate accounts for DC management (Tier 0), server administration (Tier 1), and workstation support (Tier 2).

Network segmentation contains propagation. East-west firewalls block workstation-to-server SMB while bastion host policies restrict RDP jump server capabilities.

Incident Response and Mitigation

Immediate account lockdown halts propagation. Network-wide **Disable-ADAccount** execution prevents further authentications across compromised accounts.

Mass credential rotation resets attack infrastructure. LAPS policy refresh handles local administrators; **Reset-ComputerMachinePassword** covers machine accounts.

Lateral path reconstruction identifies full scope. Event ID 4624 timelines mapped against NetFlow reconstruct hop sequences for complete endpoint reimaging.

Domain recovery eliminates persistence. Double krbtgt password rotation invalidates golden tickets; DC demotion/reinstallation removes [DCSync](#) capabilities.

Why Pass-the-Hash Is a Lateral Movement Problem

Bearer token authentication demands east-west visibility. Perimeter identity solutions track external logins but miss internal credential propagation across VLANs.

Predictable patterns separate legitimate from malicious. Administrators follow established host patterns and temporal cadences; attackers generate bursty sequences.

Continuous monitoring provides final defense layer. Single-point endpoint or [network visibility](#) permits attackers to sequence operations across detection gaps.

Deep Visibility, Advanced Threat Detection and Response: Fidelis Network

- Threat Analysis
- Data Loss Prevention (DLP)
- Integrated Deception

[Read the Datasheet](#)

The image is a stylized graphic of a datasheet for Fidelis Network. It features a large, dark blue, irregular shape resembling a handprint or a series of connected segments. The word "Fidelis" is partially visible in the top left corner of this shape. To the right of the shape, the word "Datasheet" is written in a light blue, sans-serif font. Below "Datasheet", there is a registered trademark symbol (®). The main body of the shape contains several paragraphs of text, which are partially obscured by the dark blue background. The text is in a light blue, sans-serif font. At the bottom right of the shape, the words "Fidelis Network" are written in a bold, dark blue, sans-serif font, followed by a registered trademark symbol (®). Below this, the words "Deep Visibility, Advanced Threat Detection and Response" are written in a dark blue, sans-serif font, arranged in three lines.

Fidelis
Deep Visibility, Advanced

Networks continuously grow in both size and complexity, particularly as digital transformation extends into the cloud. This creates the ideal environment for attackers to hide. Finding and stopping threats in this environment seem like an impossible task. Often, it is not until a breach will occur, but when.

How Fidelis Network Works

Fidelis Network is a proactive network (NDR) solution that provides unmatched threat detection, and faster response to threats. It can be used stand-alone, or as part of the comprehensive and active eXtended Detection and Response platform. Fidelis Network integrates with your existing security stack.

Fidelis Network automatically groups related alerts and provides malware analysis and hunting. Fidelis Network also provides forensic analysis, DLP (Data Loss Prevention) and automated security rules in one place. Users aggregated alerts, context, an investigation, deeper analysis, and more.

By collecting more than 300 metadata and files, Fidelis Network provides threat defense that competitors' NDRs cannot. Detection correlates alerts that may be related and maps them.

Fidelis Network®
Deep Visibility, Advanced
Threat Detection and
Response

The Role of Advanced Threat Detection

Network analysis decrypts behavioral context. Deep packet inspection reconstructs complete NTLM sequences across encrypted SMB3 channels that endpoint agents cannot parse.

Machine learning defeats stealth operations. Per-user authentication graphs identify service accounts logging interactively or workstation-initiated domain admin flows.

[Deception](#) forces early attacker interaction. Canary administrator shares and fake credential stores lure threat actors into monitored environments before production compromise.

Unified platforms fuse fragmented signals. [Fidelis combines NDR with deception](#) and endpoint telemetry, creating comprehensive visibility across identity, network, and process layers.

Conclusion

Hashes become bearer tokens post-extraction. MFA validates initial logon only—stolen NTLM hashes bypass all subsequent authentications completely.

Behavioral divergence trumps cryptographic validity. Legitimate administrators generate predictable patterns; attackers create spatial-temporal anomalies requiring cross-layer correlation.

Layered defenses address multiple vectors. Protocol restriction + credential isolation + memory protection + continuous monitoring create true defense-in-depth.

East-west visibility represents the final frontier. [Perimeter security](#) misses internal credential abuse powering breach escalation across enterprise networks.

Frequently Ask Questions

Is Pass-the-Hash still relevant today?

Mission-critical for attackers. MITRE ATT&CK documents active pass-the-hash usage by 40+ threat groups in 2025 operations powering ransomware deployment and APT persistence.

Can MFA prevent Pass-the-Hash attacks?

No—MFA validates initial logon only. Post-capture NTLM hashes bypass subsequent SMB/RDP/WMI authentications entirely.

Does disabling NTLM stop Pass-the-Hash completely?

Yes for pure NTLM paths. Comprehensive application compatibility testing prevents operational disruption during protocol transition.

What logs are most useful for pass the hash detection?

Core set: Security Event ID 4624 (Logon Type 3/9), 4776 (NTLM auth attempts), Sysmon 1 (process creation), Sysmon 3 (network connects), NetFlow SMB/RDP volume.

References:

-
1. [2025-dbir-data-breach-investigations-report.pdf](#)
 2. [Fidelis NDR Solution: Automated Threat Detection and Hunting | Fidelis Security](#)